

RENTLO — MASTER PROJECT SPECIFICATION & TECHNICAL BLUEPRINT

Comprehensive Pre-Development Architectural Specification & Implementation Roadmap

PROJECT DEVELOPMENT STATUS: PLANNING & BLUEPRINT PHASE (NOT YET STARTED)

This document serves as the authoritative, comprehensive **pre-development technical blueprint** for Rentlo. It specifies all architectural designs, database schemas, financial pricing models, API contracts, security controls, and infrastructure specifications that will be built during execution.

Platform Name:	Rentlo (Zero-Brokerage Real Estate Ecosystem)	Document Version:	1.0 (Master Pre-Dev Spec)
Target Stack:	Django 4.2 / React Vite / PostgreSQL / Redis	Blueprint Author:	Principal Systems Architect
Primary Domain:	rentlo.in / api.rentlo.in	Execution Status:	Planned / Ready for Dev

1. Executive Summary & Architectural Vision

Rentlo is designed as a next-generation, high-concurrency zero-brokerage real estate platform tailored specifically for the Indian rental market. The platform eliminates high traditional broker fees (typically 1-2 months' rent) by directly connecting property buyers/tenants with verified property owners.

Core Architecture Principles Specified:

- **Dual Revenue Engine:** Micro-transaction Buyer Unlocks / Multi-Pass Credit Packs combined with Owner Category Listing Fees.
- **Strict Data Privacy & BOLA Prevention:** Owner PII (phone/email) hidden behind server-side authorization; DPDP Act 2023 baseline compliance.
- **Atomic Concurrency & Financial Protection:** Webhook HMAC SHA-256 validation, Redis atomic lock checks, `select_for_update()` row locking.
- **Scalable Search Infrastructure:** Spatial PostGIS distance queries (`location__distance_lte`) with Redis response caching.

2. Complete Database Schema Specification

The database architecture is designed for PostgreSQL 15 with the PostGIS spatial extension enabled. Below is the complete relational model specification to be built:

Model Name	Key Fields & Attributes	Indexes & Constraints
User (accounts)	phone, email, roles (JSON), is_phone_verified, dpdp_consent_given, dpdp_consent_timestamp, dpdp_consent_version	Unique Index on phone & email. Role checking choices.
Property (properties)	title, property_type, status, price, exact_lat, exact_lng, location (PointField), registration_fee_paid, registration_utr	GiST Spatial Index on location. Status choices: pending, live, rejected.
Unlock (unlocks)	buyer (FK), property (FK), status (pending/paid), razorpay_order_id, razorpay_payment_id, created_at	UniqueConstraint(buyer, property, status='paid'). Index on created_at.
BuyerSubscription (unlocks)	buyer (FK), pass_type (starter/smart/pro), credits_total, credits_remaining, status (active/expired/depleted), created_at	UniqueConstraint(buyer, pass_type, status='pending'). Index on status.
IdempotencyKey (unlocks)	user (FK), key (CharField), endpoint (CharField), created_at	UniqueConstraint(user, key, endpoint). Automatic cleanup.
PlatformSettingsAuditLog (properties)	changed_by (FK), field_name, old_value, new_value, ip_address, changed_at	Immutable log table. Index on changed_at & field_name.

3. Revenue Model & Pricing Configuration Specifications

Revenue Stream	Config Parameter Name	Default Spec Value	Operational Logic Specification
Single Contact Unlock	buyer_unlock_fee	Rs. 14 / unlock	Unlocks owner phone & contact info for 1 listing.
Buyer Starter Pass	buyer_pass_starter_price	Rs. 39 (3 unlocks)	Credit pack of 3 contact unlocks.
Buyer Smart Pass	buyer_pass_smart_price	Rs. 79 (6 unlocks)	Credit pack of 6 contact unlocks + 1 agreement.
Buyer Pro Pass	buyer_pass_pro_price	Rs. 129 (10 unlocks)	Credit pack of 10 contact unlocks + 3 agreements.
Residential Listing	owner_residential_fee	Rs. 99 / listing	Single family / Independent house listing fee.
Apartment / PG Listing	owner_appt_pg_fee	Rs. 149 / listing	Flat / Multi-unit PG accommodation listing fee.
Commercial Listing	owner_commercial_fee	Rs. 199 / listing	Office / Retail shop commercial property fee.
E-Stamp Digital Draft	e_stamp_price	Rs. 499 / agreement	Digital tenancy draft generator (disabled pre-contract).

4. Authentication, Authorization & DPDP Baseline Specifications

Security & Cookie Authentication Specification:

- **HttpOnly JWT Cookies:** Access tokens (30m lifetime) and Refresh tokens (7d lifetime) stored strictly in HttpOnly, SameSite=Lax cookies, eliminating XSS token theft risks.
- **Token Rotation & Blacklisting:** SimpleJWT token rotation enabled with mandatory blacklisting upon refresh (BLACKLIST_AFTER_ROTATION = True).
- **Rate Limiting (DRF ScopedRateThrottle):** Auth OTP request restricted to 5/min, OTP verify restricted to 10/min, login restricted to 10/min.

Digital Personal Data Protection (DPDP) Act Specification:

- **Affirmative Consent Default:** dpdp_consent_given defaults to False. Consent is recorded ONLY upon affirmative user verification.
- **Server-Authoritative Policy Versioning:** dpdp_consent_version set from server config (settings.CURRENT_DPDP_POLICY_VERSION), ignoring client payloads.
- **Atomic Data Erasure (POST /api/v1/auth/data-erasure/):** User PII (name, email, phone) anonymized and outgoing chat messages scrubbed inside a single transaction.atomic() block with HTTP 500 error fallback on failure.

5. Buyer Contact Unlock & Pass Engine Specifications

The unlock engine is specified to handle single unlocks and multi-pass credit deductions with absolute financial protection:

1. **Signed Webhook Replay Protection:** Razorpay webhook payloads validated using HMAC SHA-256 over raw request body; event timestamps sourced from INSIDE signed payload with 300s window check.
2. **Atomic Event Deduplication:** Atomic cache.add(f'razorpay_webhook_txn:{event_type}:{payment_id}', 'processed', timeout=86400) prevents race condition double-crediting.
3. **Row-Level DB Locking:** Contact unlocks and pass deductions execute inside select_for_update() row locks to eliminate concurrency TOCTOU issues.
4. **Stale Pending Row Expiry:** Pending unlocks and pass purchases >15m automatically expired via created_at__lt=stale_cutoff to prevent permanent user checkout blocks.

6. Complete REST API Endpoint Blueprint Specifications

Endpoint URL Path	HTTP	Auth Level Spec	Functional Specification & Behavior
/api/v1/auth/login/	POST	AllowAnonymous	Authenticate user; set HttpOnly JWT access & refresh cookies.
/api/v1/auth/otp/request/	POST	AllowAnonymous	Request OTP for login/registration (throttled 5/min).
/api/v1/auth/otp/verify/	POST	AllowAnonymous	Verify OTP; record affirmative DPDP consent & server version.
/api/v1/auth/data-erasure/	POST	IsAuthenticated	Atomic PII anonymization & chat scrubbing per DPDP protocol.
/api/v1/properties/public/	GET	AllowAnonymous	Public property catalog search with PostGIS spatial radius query.
/api/v1/unlocks/initiate/	POST	IsAuthenticated	Initiate contact unlock or deduct pass credit (atomic lock).
/api/v1/unlocks/passess/initiate/	POST	IsAuthenticated	Initiate pass credit pack purchase with stale cleanup.
/api/v1/webhooks/razorpay/	POST	AllowAnonymous	HMAC SHA-256 signed payment gateway webhook handler.
/api/v1/properties/platform-setting s/audit-logs/	GET	IsAdmin	Admin audit trail of settings & fee changes.
/api/docs/	GET	AllowAnonymous	Interactive OpenAPI 3.0 Swagger UI documentation.

7. Security Architecture & Defensive Requirements

Security Domain	Specified Defensive Controls	Execution Status
Authentication	HttpOnly, Secure, SameSite=Lax JWT cookies. Complete elimination of XSS-vulnerable localStorage token storage.	SPECIFIED / PLANNED
Access Control (BOLA)	Server-side object authorization. Unlocked PII (phone/name) accessible only via verified BuyerUnlock records.	SPECIFIED / PLANNED
Rate Limiting	DRF ScopedRateThrottle enforcing 5 req/min on OTP request and 10 req/min on OTP verification.	SPECIFIED / PLANNED
Financial Integrity	HMAC SHA-256 webhook signature validation. Atomic DB transactions for unlock credits & pass deductions.	SPECIFIED / PLANNED
HTTP Security Headers	SECURE_BROWSER_XSS_FILTER, SECURE_CONTENT_TYPE_NOSNIFF, X_FRAME_OPTIONS=DENY, HSTS (31536000s in Prod).	SPECIFIED / PLANNED
Logging & PII Scrubbing	Custom PIIScrubbingFilter scrubbing phone numbers, passwords, and tokens from all standard logs.	SPECIFIED / PLANNED

8. Development & Implementation Roadmap

Phase	Category Specification	Key Execution Objectives	Priority
Phase 1	Core Development	Build Django backend models, REST API endpoints, JWT auth, and React Vite frontend	HIGH (Phase 1)
Phase 2	Payment & Locking	Implement Razorpay webhook HMAC verification, atomic row locking, and idempotency keys	HIGH (Phase 2)
Phase 3	Infra & Scaling	Deploy Celery background workers, PostGIS spatial search index, and Redis response caching	MEDIUM
Phase 4	Production & Legal Gate	Nginx TLS 1.3 reverse proxy, Gunicorn WSGI, and formal legal counsel DPDP review	CRITICAL GATE

9. User Roles & Platform Feature Specifications

User Role	Core Platform Features & Privileges Specified	Access Controls & Security Scope
Real Estate Agent	• Manage multi-owner property portfolios • Agent verification badge on listings • Commission tracking & lead assignment • Sub-agent team management dashboard	IsAgent permission class. Access restricted to assigned client leads & earned commissions.
Buyer / Tenant	• Spatial radius search (PostGIS / Haversine) • Single unlock (Rs. 14) or Pass credits (Starter/Smart/Pro) • Direct owner chat & visit scheduling • Saved search criteria with instant notifications	AllowAny for public search. IsAuthenticated for unlocks, chat, & pass purchase.
Property Owner	• Category listing submission (Res Rs. 99 / Apt Rs. 149 / Comm Rs. 199) • Verified tenant lead inbox & inquiry tracking • Digital rental agreement draft builder	IsAuthenticated for listing creation. Can view only leads generated for owned properties.
Platform Admin	• Moderation queue for listing approval/rejection • Global fee & settings editor with audit logging • Real-time platform revenue & analytics dashboard	IsAdmin superuser scope. Immutable logging of setting mutations & moderation actions.

10. End-to-End Real Estate Transaction Story Walkthrough

To illustrate how all user roles interact within the Rentlo platform architecture, below is a detailed step-by-step narrative describing an Owner renting out a 2BHK flat and a Buyer discovering, unlocking, visiting, and securing the property:

Act 1: Property Listing & Onboarding Payment (The Owner Journey)

Ramesh (Property Owner) wants to rent out his fully-furnished 2BHK apartment in HSR Layout, Bengaluru for Rs. 32,000/month. He navigates to Rentlo, enters his mobile number, verifies the OTP, and affirmatively agrees to the DPDP Act consent version 1.0.

Ramesh uploads property photos, selects the 'Apartment / PG' category, and sets the location pin. The platform calculates the category listing fee of **Rs. 149**. Ramesh pays via UPI. Razorpay issues a signed webhook; Rentlo verifies the HMAC SHA-256 signature and creates a pending listing record.

Act 2: Admin Moderation & Quality Verification (The Admin Journey)

Priya (Platform Admin) opens the Admin Moderation Queue. She reviews Ramesh's listing, verifies the high-resolution photos, confirms reasonable pricing for HSR Layout, and clicks **Approve Listing**. The property status immediately transitions to live.

Act 3: Discovery & Radius Search (The Buyer Journey)

Ananya (Tenant / Buyer) is looking for a 2BHK flat near her tech park. She opens Rentlo, sets a 5 km radius search around HSR Layout, and filters for 'Apartment' under Rs. 35,000. PostGIS executes a spatial distance query (`location__distance_lte`) and displays Ramesh's flat as the top result.

Act 4: Contact Unlock & Atomic Credit Deduction

Ananya loves the apartment photos but Ramesh's phone number is protected. Ananya clicks **Unlock Contact**. Since she holds an active **Smart Pass** (7 unlocks pack), Rentlo executes a `select_for_update()` lock inside a `transaction.atomic()` block, atomically deducting 1 credit and granting instant access to Ramesh's phone number.

Act 5: Chat, Visit Scheduling & Deal Closure

Ananya initiates a direct chat on Rentlo with Ramesh and schedules a physical visit for Saturday. After inspecting the flat, Ramesh and Ananya agree on terms. Ananya uses Rentlo's digital agreement draft builder to generate a standardized rental agreement draft.

Act 6: Agent Referral & Ecosystem Governance

Vikram (Real Estate Agent) monitors his agent dashboard for nearby unrepresented properties. When specialized agent listings are onboarded, Vikram assists with verification and earns a platform referral commission tracked transparently in his Agent Earnings Summary.

11. Comprehensive Master Feature Directory & Functional Explanations

Below is the complete functional feature directory of the Rentlo platform, detailing every module, capability, and user-facing feature specified for the system:

Feature Category	Feature Name & Component Specification	Functional Explanation & Operational Value
Authentication & Security	• Passwordless Mobile OTP Auth • HttpOnly JWT Cookie Engine • DPDP Consent Tracking • Atomic PII Data Erasure	Provides passwordless SMS OTP login for buyers, owners, and agents. Stores session tokens in HttpOnly SameSite=Lax cookies to neutralize XSS attacks. Enforces affirmative DPDP Act consent and single-transaction PII erasure.
Property Discovery & Search	• PostGIS Spatial Radius Query • Multi-Criteria Catalog Filters • Bounding-Box Math Fallback • Redis Search Response Cache	Allows buyers to search properties within a 1-50 km radius using PostGIS geographic distance queries (location__distance_lte). Supports filtering by price, category, city, and locality with 5-minute Redis response caching.
Contact Unlock & Passes	• Single Contact Unlock (Rs. 14) • Starter / Smart / Pro Credit Passes • Atomic Credit Deduction Locks • Stale Pending Order Cleanup	Protects owner phone numbers behind server-side authorization. Buyers unlock contact info via single micro-transactions or credit passes using select_for_update() row locks. Stale pending orders >15m automatically expire.
Payment Gateway & Webhooks	• Razorpay HMAC Signature Verify • Atomic Webhook Deduplication • Idempotency Key Enforcer • Dynamic Fee Calculator	Validates payment gateway webhooks using HMAC SHA-256 signatures over raw request bodies. Prevents race-condition double-crediting via atomic cache.add() keys and endpoint-scoped IdempotencyKey constraints.
Owner Listing Management	• Tiered Category Onboarding Fees • High-Res Image Optimization • Lead Inbox & Inquiry Tracking • Digital Agreement Draft Builder	Allows owners to list Residential (Rs. 99), Apt/PG (Rs. 149), and Commercial (Rs. 199) properties. Automatically strips image EXIF metadata, converts to WebP, and provides a lead management inbox.
Agent Ecosystem	• Multi-Owner Portfolio Manager • Verified Agent Card Badges • Referral Commission Analytics • Sub-Agent Lead Assignment	Empowers real estate agents to manage multiple client listings under a unified dashboard. Tracks earned referral commissions transparently and supports team lead distribution.
Admin & Audit Governance	• Property Moderation Queue • Global Fee & Settings Editor • Immutable Settings Audit Log • Real-Time Revenue Analytics	Gives superadmins full governance over listing approvals/rejections with review notes. Features a dynamic settings editor that automatically logs every fee/toggle mutation with admin username, old/new value, and IP address.